

CRA Mondays

Automating CRA Compliance at Scale
ORT Server Results from OCCTET and the Eclipse
Foundation Project Analysis

Open CyberSecurity Compliance Toolkit

2026/07/06





Agenda

- OCCTET in brief
- ORT Server capabilities
- Mapping CRA obligations to ORT Server capabilities
- Agentic AI workflows with ORT Server
- OCCTET findings: Large-Scale analysis
- Wrap-up
- Q&A session



WHAT IS OCCTET?

Open Source Compliance Comprehensive tools and resources designed to simplify and streamline the CRA compliance process for SME, allowing them to tackle the complexities of OSS compliance.



[OCCTET.eu](https://occtet.eu)



Co-funded by
the European Union



OCCTET - CO Funded European Project

Project ID: 101190474

Funded by: ECCCC

Call: DIGITAL-ECCC-2024-DEPLOY-CYBER-06

Duration: 24 months

Start date: November 2024

Total budget: 2,4M€

Partners: 7



ECCC 
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE



**Co-funded by
the European Union**

OCCTET project has received funding from the Digital Europe Programme (DIGITAL), under grant agreement number: 101190474. The content does not necessarily reflect the views of the European Commission. The European Commission is not liable for any use that may be made of the information contained herein.

[OCCTET.eu](https://occtet.eu)



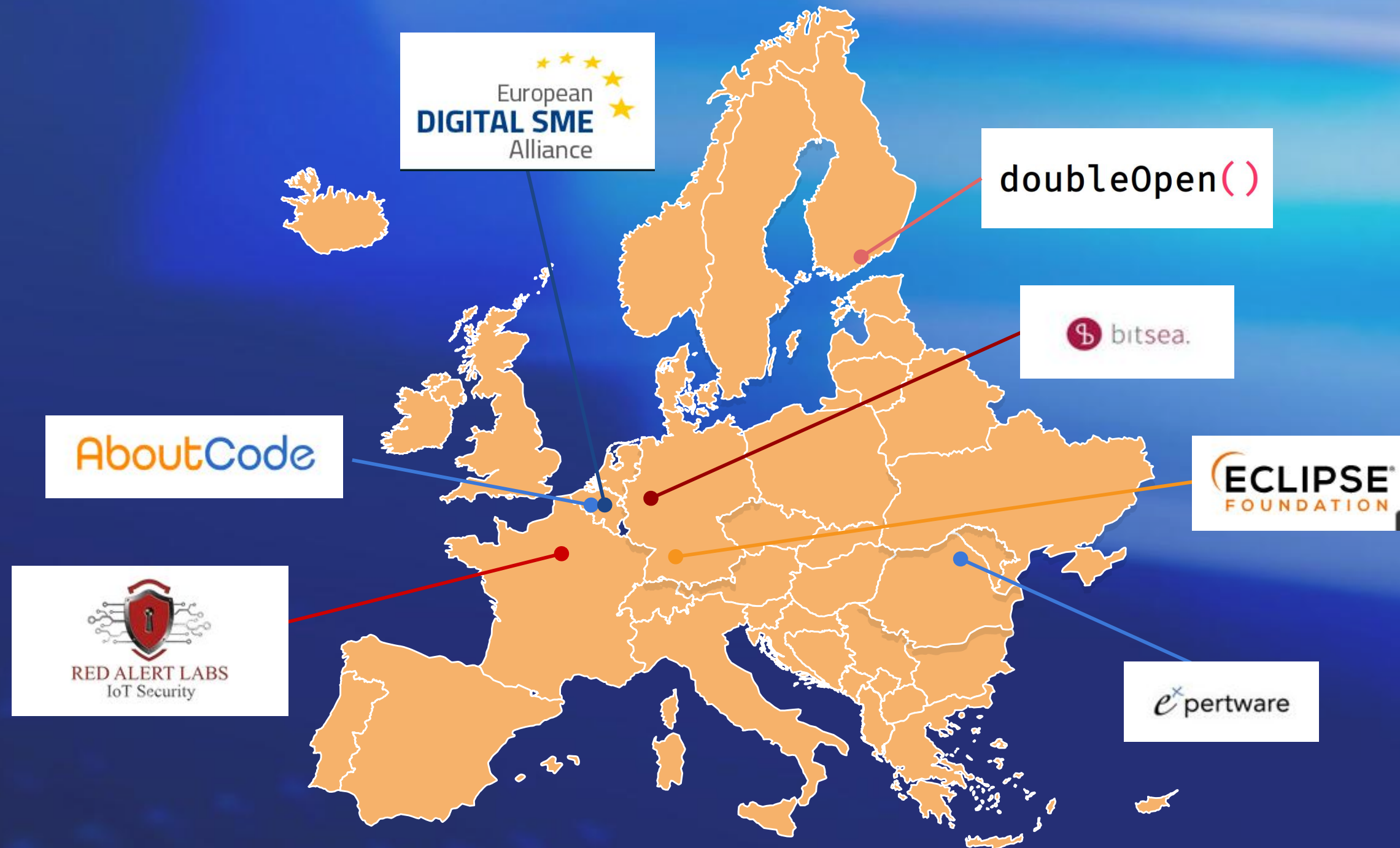
ECCC 
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE



**Co-funded by
the European Union**



Consortium Partners



OCCTET.eu



Co-funded by
the European Union

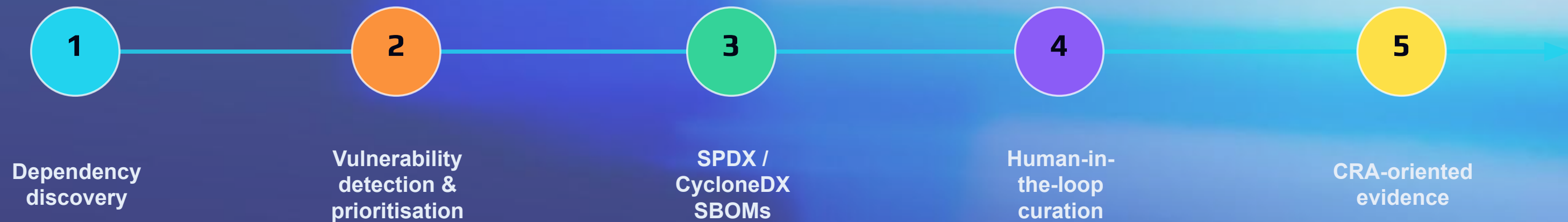


Key Ambitions

- **Understanding the Cybersecurity Challenges Faced by SMEs**
 - High costs and limited resources
 - 61% struggle with cybersecurity due to insufficient skills and expertise
- **Empower SMEs**
 - Understand and apply effortlessly the CRA
 - Strengthening the cybersecurity posture
- **Automate Open Source Software Component handling**
 - Tooling / Global Embrace
- **Enhance Visibility and Impact**
 - Open Source tools for broad adoption
 - Federated Data Approach

Demonstrating the OCCTET Toolkit

From open-source/SMEs software analysis to CRA-ready compliance evidence



ORT Server

SCA, vulnerability monitoring and SBOM generation

OCCTET Curator

Curation, enrichment and evidence preparation

Federated metadata

Reusable package and vulnerability data

OCCTET.eu



Co-funded by
the European Union



ORT Server capabilities

ORT Server: <https://eclipse-apoapsis.github.io/ort-server/>

OSS Review Toolkit: <https://oss-review-toolkit.org/ort/>



- Software asset inventory: organization - product - repository
- Software component analytics: OSS Review Toolkit, dynamic dependency resolution, all transitive ones included
 - Dependency inspection, multiple angles, health recommendations
- Vulnerability management: identification, triage, suppression, alerts
- License Compliance, license & copyright detection using scanners, such as ScanCode
- Rule engine to raise alerts
- Report generation: report/artefact creation (many types, can be configured)
- Notifier



- Technical capabilities
 - CI/CD integration for automated compliance
 - Everything can be configured as code (and UI)
 - Runs on Kubernetes,
 - API everything, UI uses the same APIs
 - IAM integrates to all typical cloud and local IAM solutions
 - Key contributors, ORT Server: Double Open and Robert Bosch
<https://projects.eclipse.org/projects/technology.apoapsis/who>
 - Key adopters, OSS Review Toolkit:
<https://github.com/oss-review-toolkit/ort/blob/main/ADOPTERS.md>

- Overview
- Compliance
- Vulnerabilities
- Search
- Packages
- Vulnerabilities
- Organization
- Secrets
- Infrastructure Services
- Users
- Settings

NIIS

Nordic Institute for Interoperability Solutions

Products

3

Add product +

Vulnerabilities

310 unresolved

Issues

229 unresolved

Rule Violations

126 unresolved

Packages

2332

Products	Runs	Last Run Status	Last Run Date	Last Job Status
Harmony	-	Contains 2 repositories 🔒 30 🛡️ 99+ ⚖️ 11		
XRd4J-Example-Adapter	6	FINISHED 🔒 0 🛡️ 0 ⚖️ 0	05.12.2025 klo 13.19.12 Petteri Kivimäki	●●●●●
X-Road	-	Contains 6 repositories 🔒 99+ 🛡️ 99+ ⚖️ 99+		

10 items per page

Page 1 of 1

Previous

All

Next

FINISHED_WITH_ISSUES

Rerun

Run ID: 1436

Revision: develop (f132b7c)

Created by: Martin von Willebrand

Created at: 20.04.2026 klo 20.03.30

Duration: 16m 20s

Overview

Compliance

- Rule Violations
- Detected Licenses
- Detected Snippets
- Vulnerabilities

Components

- Projects
- Packages
- Dependency Graphs

Reports

- SBOMs
- Other

Technical

- Issues
- Logs
- Configuration

Status

Rule Violations

26 unresolved

Vulnerabilities

24 unresolved

Issues

0 unresolved

Statistics

Packages

56



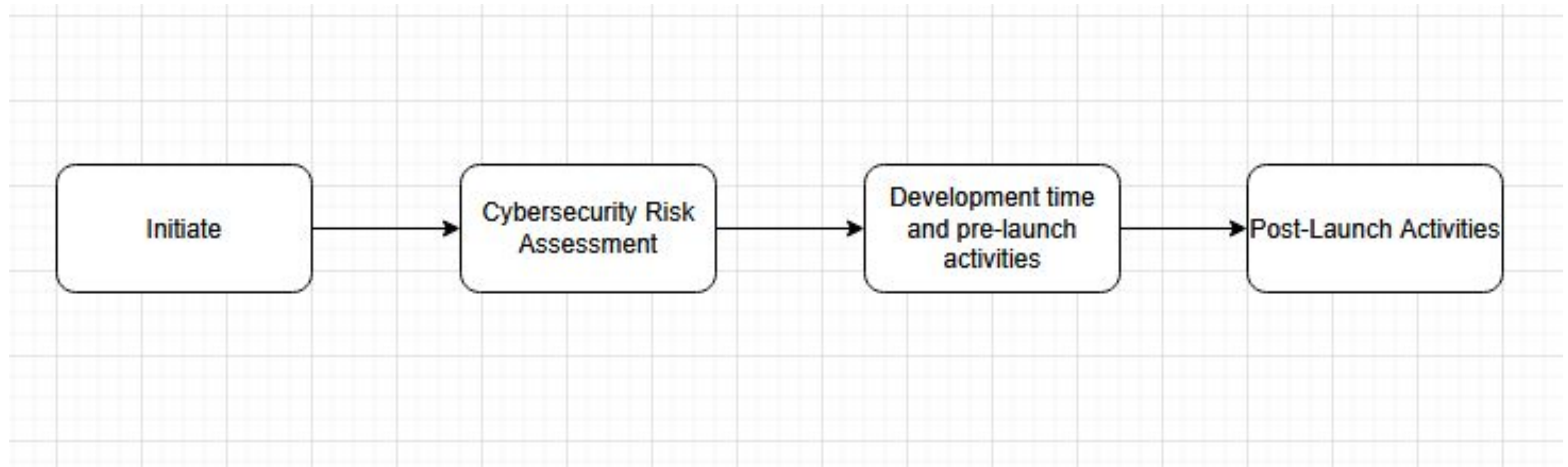
Mapping CRA obligations to ORT Server capabilities

OCCTET.eu



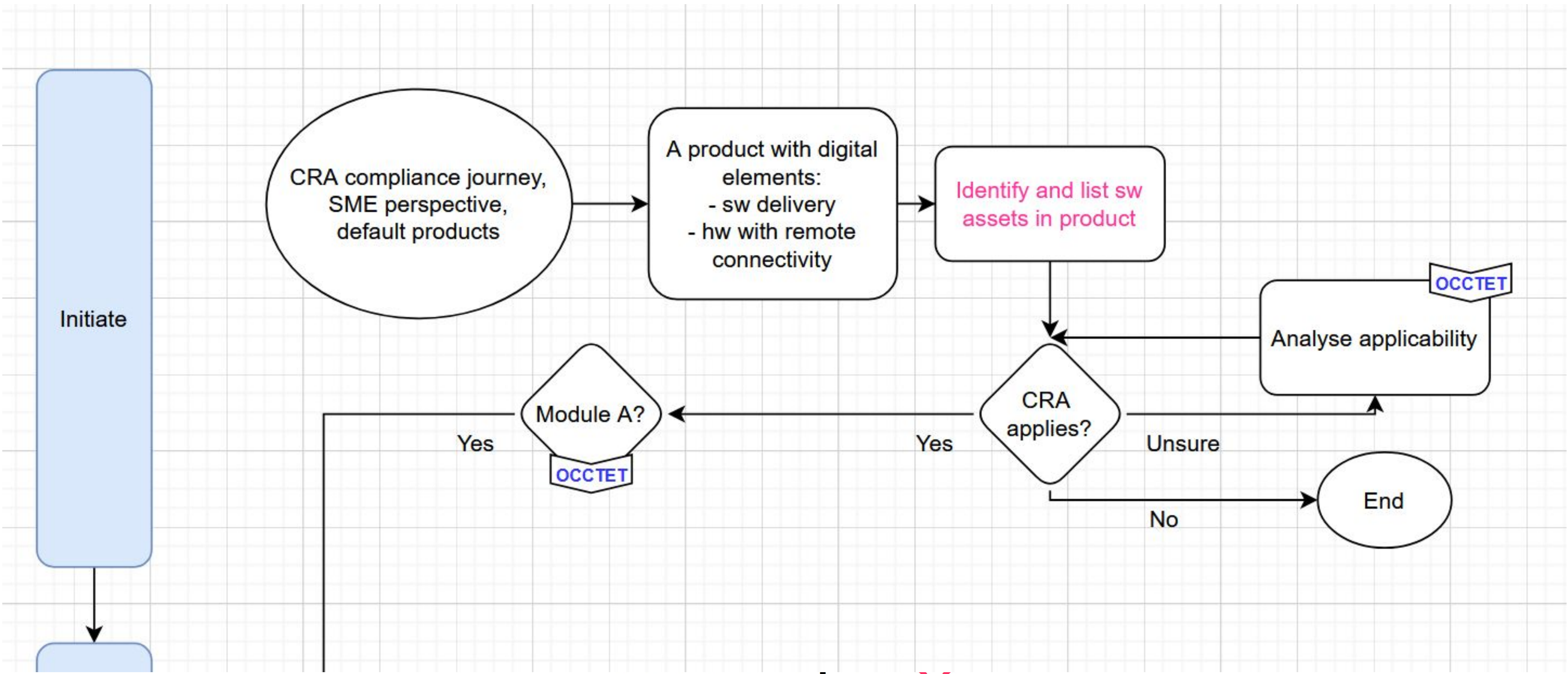
Co-funded by
the European Union

ORT Server to CRA obligations - CRA Journey

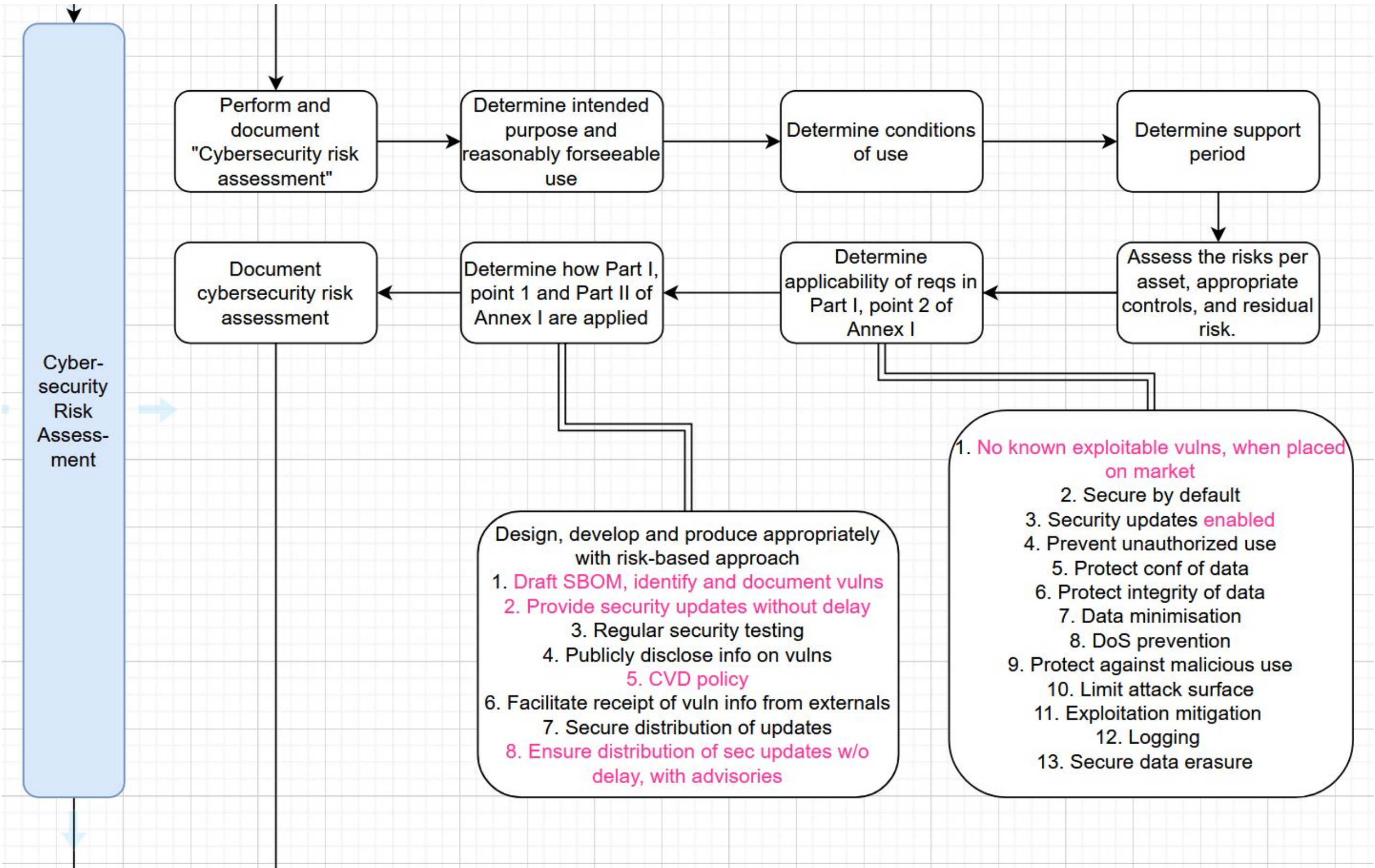


doubleOpen()

ORT Server to CRA obligations, initiate

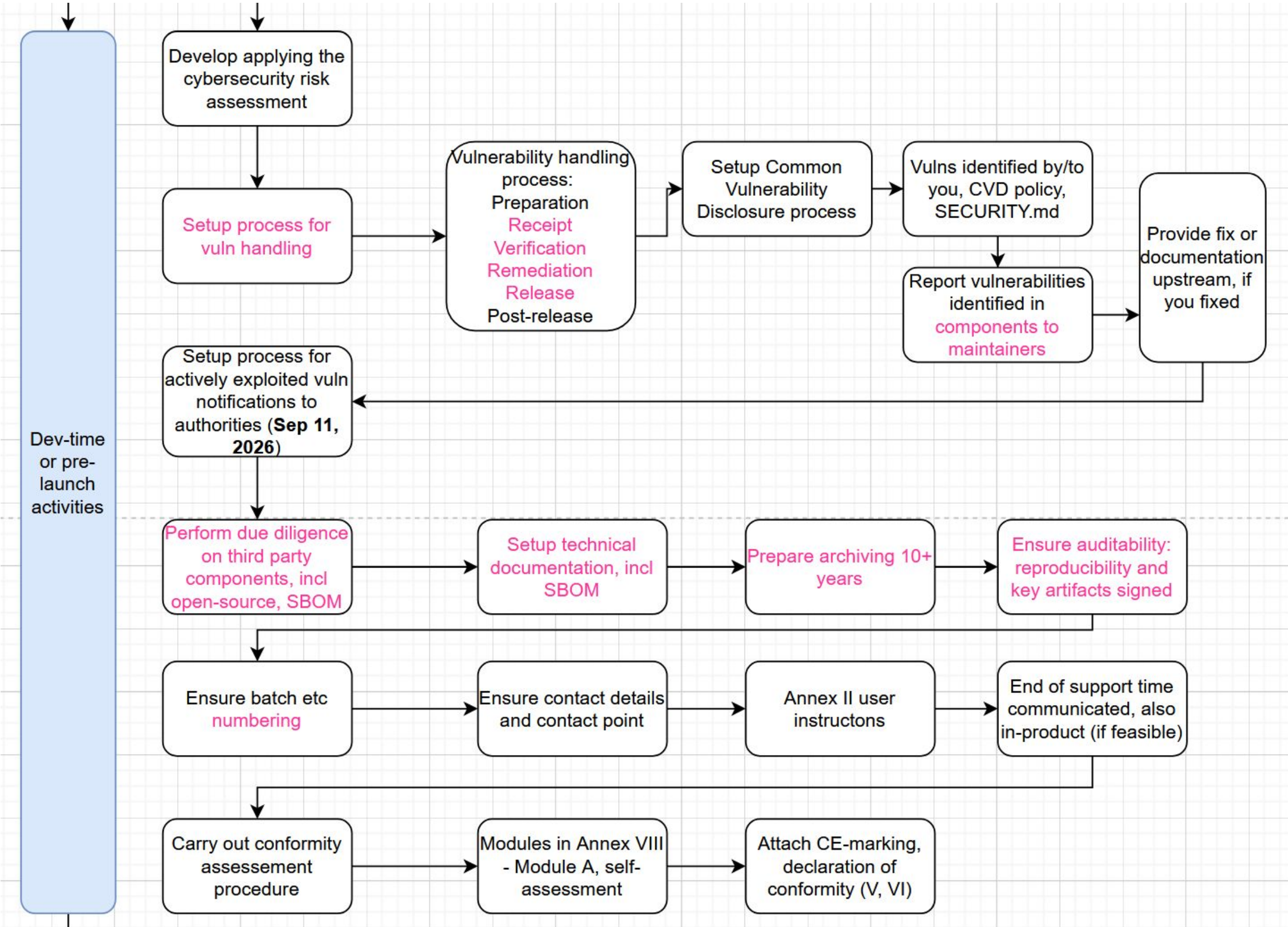


ORT Server to CRA obligations, Cybersecurity Risk Assessment



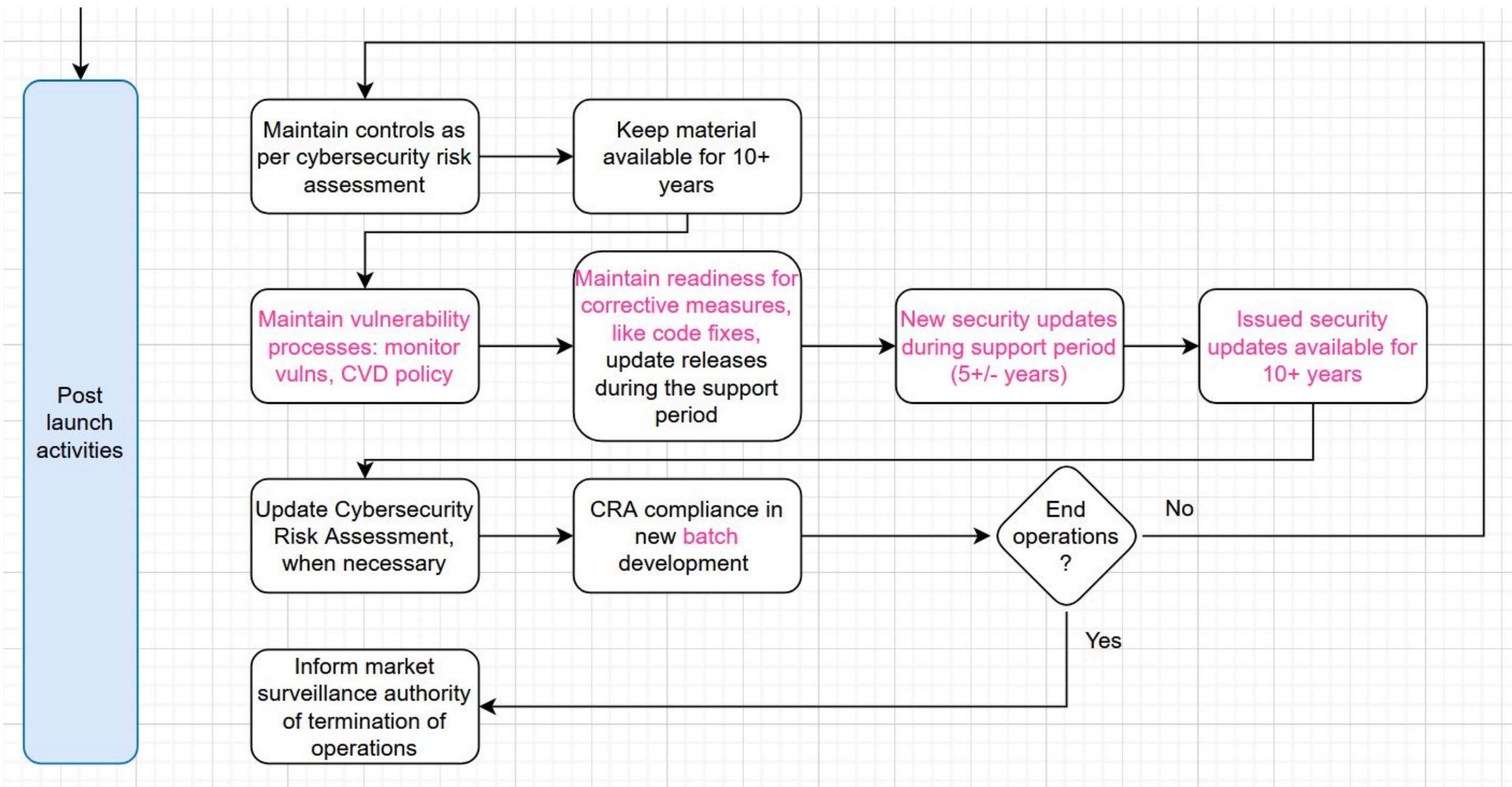
doubleOpen()

ORT Server to CRA obl., Dev-Time and Pre-Launch Activities



doubleOpen()

ORT Server to CRA obligations, Post-Launch Activities



doubleOpen()



Agentic AI workflows with ORT Server

OCCTET.eu



Co-funded by
the European Union



ORT SERVER IS WELL SUITED FOR AGENTIC WORKFLOWS

- API first - data available to agents via e.g. MCP servers
- Configuration as code - configuration available for agents
 - Configuration proposals easy to gate/inspect by humans, e.g. agent makes a PR
- ORT Server collects the foundational data algorithmically, no hallucinations possible, agents can be fed with exact data.
 - Full dependency tree
 - Vulnerability intelligence against the correct dependency tree
 - License scanner data



EXPERIENCES ON BUILDING AGENTIC WORKFLOWS

- Double Open has just launched availability of agentic license curations based on ORT Server
- Fast to do initial demonstration, but setting up reliable production workflows take more time, and AI tool understanding + require good expertise of the domain.
- Key takeaway: combine algorithmic and deterministic steps with agentic steps. If possible algorithmically do it: deterministic results, and better economics.
- Agent excels in speedy solution of human-like tasks. Are often more consistent than humans when faced with large workloads.



EXPERIENCES ON BUILDING AGENTIC WORKFLOWS

- Steps:
 - 1. Algorithmic runs on ORT Server - correct foundational data (dependencies and matching scanner detections), algorithmic filtering (rules engine).
 - 2. Algorithmic collection and deduplication of data for agents
 - 3. Guide for agents, what to inspect, what data to use, what rules to apply.
This is essentially a ~legal instruction, could be given to paralegals/curators too.
 - 4. Agents produce an audit trail documentation, including a certainty score
 - 5. Testing - both for new workflow versions AND in production



EXPERIENCES ON BUILDING AGENTIC WORKFLOWS

- Token economics
 - Caring of token economics is necessary for two reasons: hallucinations explode when context windows are exceeded; local models require small context windows
 - Currently, sub 100k context windows work well, aiming for sub 64k.
- Recording max context usage



OCCTET findings: Large-Scale OSS Analysis

D3.3 - Toolkit Demo -

<https://occtet.eu/resources/deliverables/>

OCCTET.eu



Co-funded by
the European Union



ORT Server Findings

Top GitHub OSS Projects — 96 popular repositories across 10 technology ecosystems

96
projects

10
ecosystems

6,471
dependencies

1,195
findings

120
critical

508
high

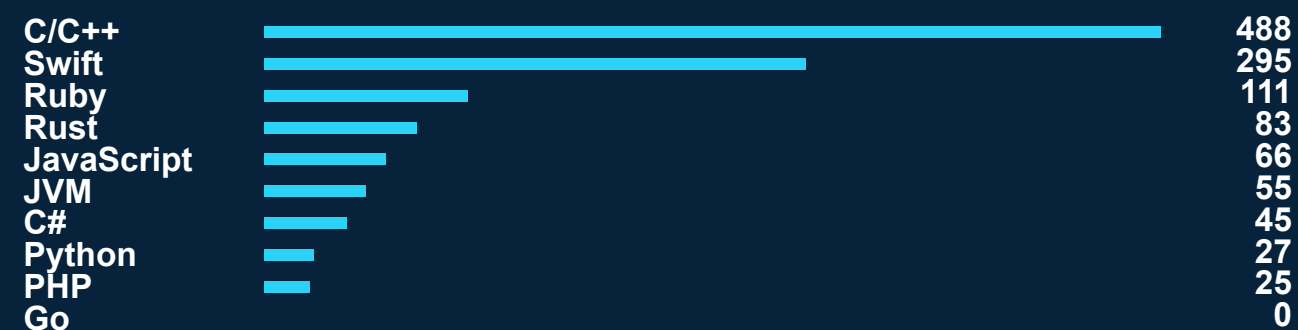
Severity mix across all findings

Advisory–package pairs surfaced by ORT Advisor using OSV and VulnerableCode.



Critical	120	Low	87
High	508	None	21
Medium	459		

Ecosystem concentration



Top 5 repositories by finding count

Deep dives include package-level advisory lists and minimum fixed versions where available.



Critical High Medium Low



GitHub Advisories / ORT Server

Key differences in vulnerability findings and dependency coverage

GitHub Advisories / Dependency Insights

Primarily GitHub Security Advisories and GitHub dependency graph data.

Repository-native dependency graph; results depend on GitHub parsing and supported manifests.

Can include GitHub Actions; in the D3.3 comparison, some transitive Python dependencies and non-standard Maven scopes were missed.

Alerts are presented in GitHub's repository-level security views.

Strong repository-native alerting and dependency visibility.

Advisory source model

Dependency resolution

Coverage differences observed

Counting semantics

Evidence for triage

ORT Server Findings

Runs advisor jobs against OSV, VulnerableCode; federated reference data can also correlate NVD, GitLab, Google OSV and upstream advisories.

Resolves the full transitive dependency graph through ORT package-manager analysis before matching advisories.

Covers large package manager ecosystems, but GitHub Actions are not analysed.

Findings are advisory–package pairs: the same advisory can appear several times if multiple packages or versions are affected.

Package-level evidence: advisory IDs, severity, affected versions, references and minimum fixed versions where available.



From GitHub Advisories to ORT Server

Key differences in vulnerability findings and dependency coverage

GitHub

Repository-level alerts; advanced security capabilities (paid-plan options), not product-centric.

- **Repo-centric:** alerts tied to one repository view
- **Limited evidence:** SBOM export available, but less integrated support for vulnerability curation and VEX-based compliance evidence.
- **Less product context:** harder to govern multi-ecosystem products
- **Paid advanced layer:** GitHub Advanced Security features depend on paid plans for private repositories



ORT Server

A free, open-source compliance tool: analyze, monitor, triage and report across products and ecosystems.

- **Open source & free:** Eclipse Project (Apoapsis), auditable code, a plugin approach, no paid security add-on required
- **Wider tech coverage:** tested across 10 different ecosystems; supports diverse stacks, and support up to 26 package managers and dependency formats.
- **Deep SCA:** dynamic transitive dependency analysis without project changes
- **Continuous monitoring:** scheduled runs, detect new advisories
- **Compliance outputs:** CycloneDX/SPDX SBOMs and VEX-ready evidence
- **Operational control:** organization/product hierarchy including: REST API, web UI, access management, ...

ORT Server Findings on SME Use Cases

What ORT Server proved with SMEs

Broad technology coverage is not only theoretical: most SME use cases tested so far could be handled by ORT Server for dependency discovery and vulnerability monitoring.

Validation scope

- 5 SME testers: DH electronics, Mahlo, ReductSoftware, A-SIT Plus and Obeo
- 9 use cases set up: real SME products and delivery models
- 8 out of 9 technologies supported: software products, SaaS-related delivery and IoT devices
- 4 additional testers in setup: validation pipeline still expanding
- Reference repositories: reduct-rs, reductstore, ...

Key takeaway

ORT Server is proving effective as the core analysis engine for SME-facing CRA evidence.
It scales across tested stacks, supports real-world models.

Technology support across SME use cases

8 supported / 1 unsupported

89% coverage



Unsupported case: legacy Visual Studio Build Tools VC2017 + CMake 3.17.3

Findings to retain

Relevant for mixed codebases

Private repository support matters for real SME projects with public and private dependencies.

Feedback improved the toolchain

Tester needs helped extend support, including Yocto-related improvements.

Boundaries are visible

Unsupported legacy build systems become explicit, making adoption planning easier.



OCCTET Curator - AI-assisted curation for CRA evidence

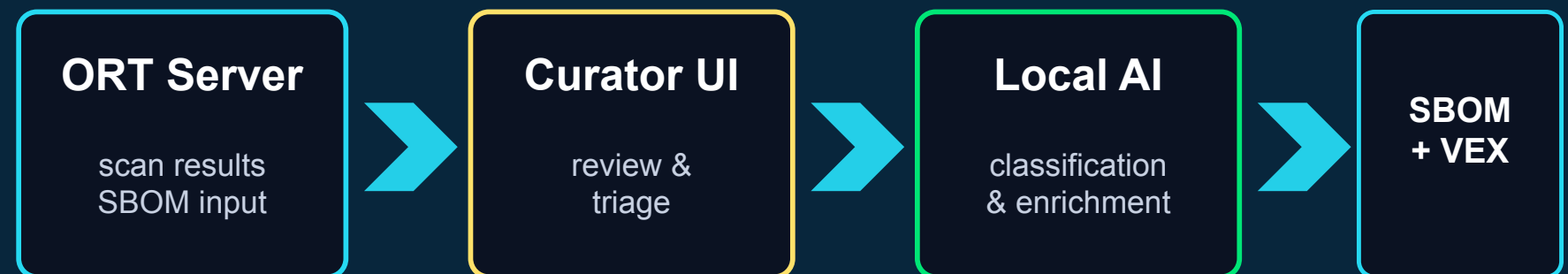
From ORT findings to curated SBOM, VEX and audit-ready compliance outputs

What OCCTET Curator adds

- Curates vulnerabilities, licences, copyright and component metadata
- Detects false positives and assists licence classification with local LLMs
- Enriches components with PURL-based metadata from external sources
- Exports validated SBOMs with annotated vulnerability information
- Supports structured VEX statements for exploitability decisions

Curation workflow: from analysis to CRA evidence

The Curator complements ORT Server by adding review, enrichment and export capabilities for auditable security documentation.



Validated with real SME and OSS use cases

SME testers include ReductStore and Obeo/Sirius Web; OSS validation spans .NET, Python, Swift, Go, Ruby, JVM, JavaScript and iconic projects such as Adoptium, Eclipse IDE, Mosquitto, Tomcat and Kafka.

OCCTET.eu



Co-funded by
the European Union



ORT Server - Eclipse Projects

Findings across 348 Eclipse projects and 3,600+ GitHub/GitLab repositories

348 projects 3,600+ repositories 74,286 packages 32,177 vulnerabilities 5,267 critical

Portfolio-scale workload

ORT Server consolidates repository, package and vulnerability evidence into one operational analysis view for Eclipse projects.

43.3% of detected packages are linked to at least one vulnerability finding



32,177 vulnerabilities / 74,286 packages

16.4% of vulnerability findings are critical, creating a prioritized triage backlog

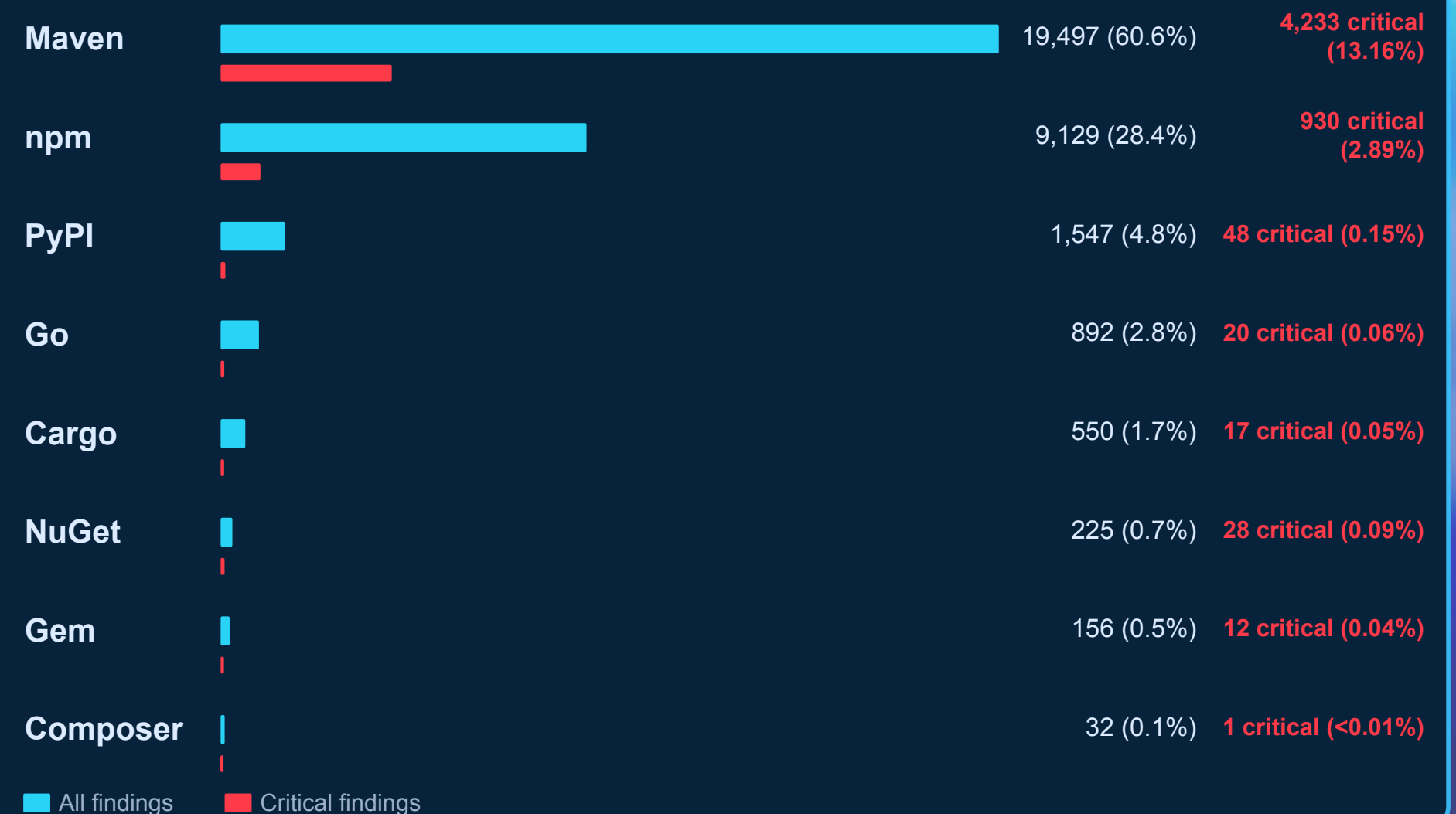


5,267 critical / 32,177 vulnerability findings

● 348 Eclipse projects connected to 3,600+ repositories on GitHub and GitLab.

Vulnerability findings by package ecosystem

All findings and critical findings shown against the overall 32,177 vulnerability workload.





Conclusion

OCCTET.eu



Co-funded by
the European Union



OCCTET.eu



Co-funded by
the European Union



Open Discussion - Q&A

OCCTET.eu



Co-funded by
the European Union

Be part of the OCCTET Community!

Follow us on LinkedIn and visit our website: occtet.eu
For any inquiries you can reach out at: occtet-eu@eclipse.org



Scan the QR code for easy access
to our Survey and Wishlist!



The OCCTET project is funded by the European Union under Grant Agreement 101190574. The European Commission's support for the production of this publication does not constitute an endorsement of the contents, which reflect the views only of the authors, and the Commission cannot be held responsible for any use which may be made of the information contained therein.



Title

OCCTET.eu



Co-funded by
the European Union



OCCTET.eu



Co-funded by
the European Union